

Responsible Disclosure Policy

PUBLIC POLICY

Zero-Day Vulnerability Discovery During Authorized Scans · Chelys Security, Inc. · v1.0

EFFECTIVE DATE	May 4, 2026
SCOPE	All zero-day and novel vulnerabilities discovered by Chelys Security agents during authorized customer scans
DOCUMENT OWNER	Head of Engineering / CISO
REVIEW FREQUENCY	Annually, or within 30 days of any coordinated disclosure event
CONTACT	security@chelyssecurity.com
VERSION	1.0

1. Purpose and Context

Chelys Security operates autonomous penetration testing agents that scan customer systems for vulnerabilities. In the course of authorized testing, these agents may discover vulnerabilities that are **previously unknown to the affected software vendor** — commonly referred to as zero-day vulnerabilities.

This policy governs what Chelys Security and its customers do when a zero-day or novel vulnerability is discovered during a scan. The core tension is this: the customer hired Chelys to find their weaknesses, and they own the finding — but the vulnerability may exist in third-party software that affects thousands of other organizations who have no idea they are at risk.

This policy resolves that tension by establishing clear roles, a standardized disclosure timeline, and escalation procedures that protect the customer, the affected vendor, and the broader public — in that order of priority.

2. What Qualifies as a Zero-Day Under This Policy

This policy applies when a Chelys scan produces a finding that meets **all three** of the following criteria:

1. **Novel:** The vulnerability has no existing public CVE, security advisory, patch, or vendor acknowledgment at the time of discovery.
2. **Exploitable:** The finding includes confirmed or highly credible evidence of exploitability — not a theoretical weakness. Chelys agents must have either (a) demonstrated exploitation or (b) produced

evidence a qualified security researcher would reasonably assess as exploitable.

3. **Third-party software:** The vulnerability exists in software the customer did not write — a commercial product, open-source library, firmware, or operating system component used by the customer. (Vulnerabilities in the customer's own code are fully the customer's property to handle as they choose.)

Note: Misconfigurations, weak credentials, and unpatched known CVEs are not zero-days under this policy — they are standard pentest findings delivered to the customer with no vendor notification obligations. Only novel, exploitable vulnerabilities in third-party software trigger this policy.

3. Roles and Responsibilities

PARTY	ROLE	OBLIGATIONS UNDER THIS POLICY
Customer	Scan authorizer; primary disclosure decision-maker	Receives the finding first; decides whether to pursue coordinated disclosure or handle privately; must not publicly disclose before the vendor has been notified and given the standard response window; retains final authority over the timing and content of disclosure for their specific instance
Chelys Security	Discovering party; disclosure coordinator	Identifies the finding as a potential zero-day; notifies the customer immediately; provides technical documentation; assists with vendor notification if the customer requests; maintains confidentiality of the finding until disclosure; may escalate to CERT/CC if the vendor is unresponsive and public risk is high
Software Vendor	Affected party; patch developer	Receives notification from customer (with Chelys's technical documentation); expected to acknowledge receipt within 7 days and provide a patch or remediation timeline within 90 days
CERT/CC or Relevant CSIRT	Neutral coordinator (escalation only)	Engaged only if the vendor is unresponsive after 30 days, or if the vulnerability poses imminent, widespread public risk. CERT/CC assists with vendor contact and can help coordinate multi-party disclosure if multiple vendors are affected

4. Discovery Scenarios

Scenario A — Zero-day in Third-Party Software Running on Customer's Systems

Most common

Example: Chelys discovers a remote code execution vulnerability in a specific version of Nginx, Apache Tomcat, or a SaaS SDK the customer uses. The vulnerability is not in the customer's code — it is in the vendor's product.

Who is at risk: The customer and every other organization running the same software version.

Chelys's default action: Notify the customer immediately. Recommend coordinated disclosure to the vendor. Assist the customer with drafting the vendor notification. Follow the 90-day timeline below. If the customer declines to pursue disclosure, Chelys reserves the right to notify CERT/CC if it assesses the public risk as critical.

Scenario B — Zero-day in Customer's Own Product (They Are the Vendor)

Customer-owned finding

Example: Chelys is pentesting a SaaS company and discovers a zero-day in that company's own application — a vulnerability that would affect their end users.

Who is at risk: The customer's own end users and customers.

Chelys's action: This finding belongs entirely to the customer. Chelys delivers it as a standard critical finding. The customer decides whether and how to disclose to their users. Chelys does not contact regulators, the press, or CERT/CC without the customer's consent in this scenario. Chelys recommends the customer engage their own legal counsel on disclosure obligations (particularly if user PII was exposed).

Scenario C — Zero-day Affecting Multiple Vendors or Widespread Infrastructure

High public impact

Example: Chelys discovers a vulnerability in a widely-deployed open-source library (e.g., a cryptography library, a logging framework) that would affect millions of systems if exploited.

Who is at risk: The broader internet.

Chelys's action: Notify the customer. Simultaneously engage CERT/CC as a coordinator (with the customer's knowledge). CERT/CC handles multi-vendor notification. The 90-day timeline applies from the date of CERT/CC engagement. Chelys will not withhold disclosure of a critical, widely-exploitable vulnerability indefinitely at a single customer's request if doing so creates unreasonable risk to the public.

Example: After Chelys notifies the vendor privately, threat intelligence sources confirm the same vulnerability is being actively exploited in the wild by unknown actors — before a patch is available.

Chelys's action: The 90-day timeline is immediately suspended. Chelys notifies CERT/CC and recommends emergency public disclosure of the vulnerability class (without full exploit details) to allow defenders to implement mitigations. The customer is informed and consulted before any public statement. Full exploit details are withheld until a patch is available or 7 days after public disclosure of the vulnerability class, whichever is sooner.

5. Standard 90-Day Coordinated Disclosure Timeline

Chelys follows the **90-day coordinated vulnerability disclosure** standard established by Google Project Zero and adopted by CERT/CC. The clock starts on the date Chelys notifies the software vendor.

D0
Day 0

Discovery & Internal Triage

Chelys agent flags finding as potential zero-day. Security Lead reviews evidence and confirms it meets the criteria in Section 2. Finding is marked `zero_day_candidate` in the platform and access is restricted to org admin only.

D1
Day 1

Customer Notification (Required within 24 hours)

Chelys notifies the customer via secure channel with: full technical write-up, proof-of-concept evidence, CVSS score, affected component and version, recommended immediate mitigations, and this policy. Chelys recommends the customer apply temporary mitigations immediately while disclosure proceeds.

D7
Day 7

Vendor Notification Deadline

The customer (with Chelys's assistance if requested) sends formal notification to the software vendor's security team. Chelys provides the vendor notification template below. Notification is sent to the vendor's published security contact, security@[vendor].com, or via their bug bounty platform if one exists. CERT/CC is CC'd if no vendor security contact can be located.

D14
Day 14

Vendor Acknowledgment Expected

The vendor is expected to acknowledge receipt and confirm they are investigating. If no acknowledgment is received by Day 14, Chelys sends a follow-up. If no response by Day 30, CERT/CC is engaged as a coordinator regardless of customer preference (see Section 6).

D45

Day 45

Patch Timeline Check-In

Chelys requests a patch availability date from the vendor. If the vendor confirms a patch will be available before Day 90, no action is required. If the vendor indicates the patch will take longer than 90 days, a timeline extension of up to 45 additional days (total 135 days) may be granted at Chelys's discretion if: (a) the vendor is actively working on a patch and (b) no active exploitation is detected.

D90

Day 90

Public Disclosure Deadline

Regardless of patch availability, the vulnerability is disclosed publicly on Day 90. If a patch is available, disclosure includes full technical details. If no patch is available, disclosure includes the vulnerability class, affected versions, and available mitigations — but withholds specific exploitation details for up to 14 additional days to give defenders time to apply mitigations. The CVE is requested from MITRE if not already assigned by the vendor.

Post

After

Post-Disclosure

Chelys publishes a security advisory on its website crediting the discovering customer (if they consent) or listing the discovery as "discovered during an authorized Chelys Security scan." The finding is added to Chelys's internal threat intelligence database to improve future detection templates.

6. Unresponsive or Hostile Vendor Escalation

If the vendor does not acknowledge the report within 30 days, or actively threatens legal action against the disclosing parties, the following escalation path applies:

- 1 Day 30 — Engage CERT/CC:** Notify CERT/CC (cert@cert.org) with the full technical details and disclosure history. CERT/CC has established vendor relationships and legal standing that can accelerate vendor response.
- 2 Day 45 — Vendor's industry regulator:** For financial, healthcare, or critical infrastructure vendors, notify the relevant sector regulator (OCC, HHS, CISA) that a known unpatched vulnerability exists in their regulated software. Regulators can compel action that Chelys cannot.
- 3 Day 90 — Full public disclosure proceeds** on schedule regardless of vendor response. Chelys publishes the advisory. The vendor's non-response is documented in the advisory. Vendors who threaten legal action against good-faith security researchers are identified as such in the advisory.

Legal safe harbor: All disclosure activities conducted under this policy are performed in good faith, on the basis of authorized testing, consistent with the Computer Fraud and Abuse Act (CFAA) safe harbor for security research under 18 U.S.C. § 1030, and consistent with the principles established in *Van Buren v. United States* (2021). Chelys's legal counsel reviews all public disclosures before publication.

7. CVE Assignment Process

A CVE (Common Vulnerabilities and Exposures) identifier provides a public, permanent reference for the vulnerability. CVE assignment follows this process:

1. **Check for existing CVE:** Search the NVD and vendor advisories before requesting a new CVE.
2. **Vendor requests CVE:** The preferred path — the software vendor requests the CVE from their CVE Numbering Authority (CNA). Most major vendors (Microsoft, Apple, Cisco, Red Hat, etc.) are CNAs.
3. **CERT/CC requests CVE:** If the vendor is not a CNA or is unresponsive, CERT/CC can request the CVE on behalf of the reporting party via the CERT/CC CNA process.
4. **MITRE direct request:** If neither of the above is possible, submit directly to MITRE at cve.mitre.org/cve/request_id.html. MITRE assigns CVEs as the CNA of last resort.
5. **Chelys records the CVE:** Once assigned, the CVE is added to the customer's finding record in the platform and included in all public disclosure materials.

8. Notification Templates

8A. Vendor Notification (Sent on Day 7)

Subject: [SECURITY VULNERABILITY REPORT] [Product Name] [Affected Version] – Coordinated Disclosure

To: security@[vendor].com (or vendor bug bounty platform)

CC: cert@cert.org (if no vendor security contact is available)

Dear [Vendor] Security Team,

We are writing to notify you of a security vulnerability discovered during an authorized penetration test of one of our customers' environments. The vulnerability exists in your product [Product Name] and affects version(s) [X.X.X].

VULNERABILITY SUMMARY

Type: [e.g., Remote Code Execution / Authentication Bypass / SQL Injection]

CVSS Score: [X.X – Critical / High / Medium]

Affected Product: [Product Name] version [X.X.X] (and potentially earlier versions)

Affected Component: [e.g., the login endpoint, the file upload handler, the XML parser]

Discovery Date: [Date]

Discovered By: Chelys Security, Inc. on behalf of an authorized customer (customer identity withheld per engagement confidentiality)

TECHNICAL DETAILS

[Detailed technical description of the vulnerability – how it works, what an attacker can do]

PROOF OF CONCEPT

[Minimal reproduction steps or evidence demonstrating exploitability – sufficient to confirm

the vulnerability without enabling mass exploitation]

IMMEDIATE MITIGATION

[Any configuration change, WAF rule, or temporary workaround available while a patch is developed]

DISCLOSURE TIMELINE

This report is being made under a 90-day coordinated disclosure policy:

- Day 0 (Discovery): [Date]
- Day 7 (This notice): [Date]
- Day 90 (Deadline): [Date – the vulnerability will be publicly disclosed on this date regardless of patch availability]

We request that you:

1. Acknowledge receipt of this report within 7 days
2. Provide an expected patch availability date by Day 45 ([Date])
3. Coordinate with us on the content and timing of the public advisory

We are committed to working with you to ensure a responsible disclosure that protects users while giving your team reasonable time to develop a fix.

Contact: security@chelyssecurity.com

PGP key available on request.

Chelys Security, Inc.

Utah, United States

8B. Public Advisory Template (Published on Day 90)

CHELYS SECURITY ADVISORY – [Advisory ID: CHELYS-[YEAR]-[NNN]]

Published: [Date]

CVE: [CVE-YYYY-NNNNN]

CVSS: [Score] ([Critical/High/Medium])

AFFECTED PRODUCT

Product: [Vendor] [Product Name]

Versions: [X.X.X] and earlier

Fixed In: [X.X.Y] (released [Date]) / No patch available as of [Date]

VULNERABILITY DESCRIPTION

[One-paragraph plain-language description of the vulnerability and its potential impact]

TECHNICAL DETAILS

[Full technical write-up – vulnerability class, root cause, attack vector, affected code component]

PROOF OF CONCEPT

[Included if a patch is available. Withheld for 14 days post-disclosure if no patch is available.]

MITIGATION

```
[Patch: upgrade to version X.X.Y]
[Workaround: [configuration change or WAF rule] if no patch is available]
```

DISCLOSURE TIMELINE

```
[Date] - Vulnerability discovered during authorized Chelys Security scan
[Date] - Customer notified
[Date] - Vendor notified
[Date] - Vendor acknowledged / did not respond
[Date] - CERT/CC engaged (if applicable)
[Date] - Patch released (if applicable)
[Date] - Public disclosure
```

CREDIT

```
Discovered during an authorized Chelys Security autonomous penetration test.
Customer: [Name if consented / "withheld at customer's request"]
```

CONTACT

```
security@chelyssecurity.com
```

9. Confidentiality and Customer Protections

- **Customer identity is protected:** Chelys never discloses the customer's identity to the vendor or the public without explicit written consent from the customer. Vendor notifications state the vulnerability was "discovered during an authorized penetration test" without naming the customer.
- **No exploit weaponization:** Chelys does not publish working exploit code, Metasploit modules, or other weaponized proof-of-concept material in any public advisory. Minimal reproduction evidence is shared only with the vendor under confidentiality.
- **Finding access restricted:** Zero-day candidate findings are visible only to the customer's org admins within the platform. They do not appear in any cross-org analysis, benchmarking, or aggregate reporting.
- **No market disclosure:** Chelys employees are prohibited from trading in the securities of any vendor affected by an undisclosed vulnerability discovered under this policy. This policy does not create an obligation to notify financial regulators — that assessment is the customer's and Chelys's legal counsel's responsibility on a case-by-case basis.

10. Reporting Vulnerabilities in the Chelys Platform

If you are a security researcher who has discovered a vulnerability in the Chelys Security platform itself (not a customer's system), please report it to:

security@chelyssecurity.com

We commit to:

- Acknowledging receipt within **2 business days**

- Providing a preliminary assessment within **7 business days**
- Working toward a fix within **90 days** of confirmation
- Not pursuing legal action against researchers acting in good faith
- Crediting the researcher in the fix advisory (unless anonymity is requested)

Safe Harbor: Chelys Security will not initiate legal action against security researchers who discover and report vulnerabilities in the Chelys platform in good faith, provided they: (a) do not access customer data beyond what is necessary to demonstrate the vulnerability; (b) do not publicly disclose before the agreed coordinated disclosure date; and (c) act consistently with this policy.

11. Edge Cases and Policy Decisions

What if the customer asks us never to disclose?

For vulnerabilities in the customer's own code (Scenario B), Chelys respects the customer's decision. For vulnerabilities in third-party software affecting the broader public (Scenarios A and C), Chelys will not agree to permanent non-disclosure. If a customer contractually prohibits Chelys from disclosing a critical public-risk vulnerability, Chelys reserves the right to terminate the engagement and engage CERT/CC directly. This position is stated in Chelys's Terms of Service.

What if the vulnerability is already being sold on dark web markets?

If threat intelligence confirms the vulnerability is actively being sold or exploited, the 90-day timeline is immediately suspended and emergency disclosure procedures from the Incident Response Plan (Scenario D) apply. Immediate limited disclosure to CISA and relevant sector ISACs (Information Sharing and Analysis Centers) is authorized without customer approval in this scenario.

What if two Chelys customers independently find the same zero-day?

Chelys will not disclose to either customer that the other has found the same vulnerability. The finding records remain org-isolated per standard multi-tenancy rules. Chelys will coordinate a single vendor notification on behalf of both customers (without revealing either's identity to the other) and will submit a single CVE request.

12. Document Control

This policy is reviewed annually and updated within 30 days of any coordinated disclosure event. Changes require approval from the Head of Engineering and Legal counsel. The current version is always available at **chelyssecurity.com/responsible-disclosure**.

